

Incident Communication Plan

Document Control

Field	Value
Document ID	STD-SEC-004-B
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Owner	CISO / Legal / Communications
Classification	Internal — Restricted Distribution
Parent Policy	POL-SEC-004 — Incident Response Policy

Purpose

This plan defines who must be notified during a security incident, when, by whom, and through what method, to ensure timely internal decision-making and compliance with regulatory notification deadlines, including the GDPR's 72-hour requirement under Article 33.

Communication Matrix

Stakeholder	When to Notify	Method	Owner
Incident Response Manager	Immediately upon IRT activation (Medium and above)	Phone/SMS call-tree, incident management platform	SOC / Security Analyst

Executive Management / Executive Sponsor	Immediately for Critical; within 4 hours for High; summary reporting for Medium/Low	Phone/SMS call-tree for Critical; secure email/incident platform otherwise	Incident Response Manager
Legal Counsel	Immediately upon confirmation of any incident involving personal data, regulatory exposure, litigation risk, contractual notification obligations, or potential criminal activity	Phone call followed by secure email	Incident Response Manager
Data Protection Officer (DPO)	Immediately upon any suspicion of a personal data breach, to start the GDPR 72-hour assessment clock	Phone call and secure email	Incident Response Manager / Legal
OT/Site Operations Manager	Immediately for any incident affecting or potentially affecting OT/IoT/production systems	Phone call, on-site notification	SOC / Security Analyst
Communications/PR	As soon as external or high-visibility internal communication may be required (typically High/Critical)	Secure email, direct briefing	Incident Response Manager / Executive Sponsor

Regulators (Data Protection Authorities)	Within 72 hours of the organization becoming aware of a qualifying personal data breach (GDPR Article 33); per applicable timelines for other regulators	Official regulator notification channel/portal	Legal / DPO
Affected Data Subjects / Customers	Without undue delay where the breach is likely to result in a high risk to individuals' rights and freedoms (GDPR Article 34), or per contractual notification terms	Direct email/letter; public notice only if direct contact is infeasible	Communications / Legal
Affected Employees (as users)	As soon as practical once containment is underway, if action is required of them (e.g., password reset, device check)	Internal email, intranet banner, manager cascade	IT Support / Incident Response Manager
Law Enforcement	Where the incident may constitute a crime (e.g., ransomware, fraud, IP theft), as determined by Legal	Formal report via Legal Counsel/CISO to relevant national cyber authority	Legal / CISO
Cyber Insurance Provider	As soon as practical for any incident that may trigger a claim; mandatory for Critical incidents	Formal notification per policy terms	Legal / Finance
Affected Vendors/Partners	As soon as containment allows, if shared or connected systems may be affected	Direct account-manager/security contact notification	Incident Response Manager

Board of Directors	For Critical incidents with material business, financial, or reputational impact	Executive briefing (verbal/written summary)	Executive Sponsor / CISO
--------------------	--	---	--------------------------

Notification Timing by Severity

Severity	Internal Notification	External/Regulatory Notification
Critical	Executive Sponsor, Legal, DPO notified within 30 minutes	Regulatory/customer notification assessment begins immediately; GDPR 72-hour clock tracked from confirmed awareness
High	Incident Response Manager and relevant leads notified within 1 hour; Legal/DPO looped in if data or legal exposure suspected	Assessed case-by-case; regulatory notification prepared if personal data breach confirmed
Medium	Incident Response Manager notified within 4 business hours	Typically not required unless scope escalates
Low	Logged; summarized in periodic reporting	Not applicable

Message Approval

All external communications (customer notices, media statements, regulatory filings) must be reviewed and approved by Legal Counsel and the Executive Sponsor before release. No employee other than designated Communications/PR spokespeople may speak to media or post publicly about an active incident.

Communication Channels

- **Internal/IRT coordination:** Dedicated incident management platform and a secure conferencing bridge; phone/SMS call-tree for Critical incidents where system availability may be affected
- **Executive updates:** Scheduled briefings at intervals set by the Incident Response Manager (minimum every 4 hours for Critical incidents until stabilized)

- **Regulatory notifications:** Official channel/portal of the relevant supervisory authority, prepared jointly by Legal and DPO
- **Customer/public notifications:** Company-approved templates, reviewed by Legal and Communications, distributed via direct contact and/or the corporate website/status page as appropriate

Revision History

Version	Date	Author	Description
1.0	2026-08-19	CISO / Legal / Communications	Initial release, companion to Incident Response Policy POL-SEC-004